MFA: Azure AD Limitations — Gambling Levy Portal

Gambling Levy Platform – Why Custom MFA Instead of Azure AD MFA

Document Version: 1.0 | **Date:** February 2026

Overview

This document explains why we implemented custom TOTP-based MFA instead of relying on Azure AD's built-in MFA capabilities.

Our Setup

- **Azure AD External ID / Entra External ID** (not B2C)
- Users with emails from **different domains** (e.g., `user@council-a.gov.uk`, `user@council-b.gov.uk`)
- Using **federated email identity** with Email OTP for sign-in

The Problem

1. Azure AD MFA is tied to the tenant, not the user's email domain

- MFA policies in Azure AD apply to users *in your tenant*
- But our users authenticate via federated identity (email OTP)
- Azure AD sees them as "external" or "guest-like" users

2. Federated Identity Bypass

When using `SignInType = "federated"` with `Issuer = "mail"`, the authentication flow is:

```
User enters email → Azure sends OTP to email → User enters OTP → Token issued
```

- This is essentially **email-based authentication**, not password-based
- Azure AD's built-in MFA (Authenticator, SMS) doesn't integrate cleanly with this flow

3. Conditional Access Limitations

Conditional Access policies that enforce MFA typically require:

- Users to have a registered authentication method in Azure AD
- Users to be "members" not "guests" or federated identities
- External/federated users often can't register MFA methods in your tenant

4. No Control Over External Domains

- You can't enforce MFA registration for `@council-a.gov.uk` users
- Their home tenant controls their MFA, not yours
- If they don't have MFA in their home tenant, you can't force it

Why Custom MFA Solves This

Azure AD MFA	Custom TOTP MFA
Tied to Azure tenant	Tied to your application
Requires user registration in Azure	Registration in your app
Doesn't work with federated email auth	Works after any authentication
Can't enforce for external domains	Enforced for all users regardless of domain
Microsoft controls the flow	You control the flow

Our Implementation

We implemented a custom TOTP-based MFA system that:

1. **Works with any authenticator app** (Microsoft Authenticator, Google Authenticator, Authy, etc.)
2. **Sits on top of Azure AD authentication** - users first authenticate via Azure AD, then verify MFA
3. **Is enforced for all users** regardless of their email domain
4. **Provides recovery codes** for account recovery
5. **Uses industry-standard TOTP** (RFC 6238) for compatibility

Summary

Azure AD MFA assumes users are **members of your tenant** with registered authentication methods. Our users are **federated identities** from various domains, so Azure AD's MFA doesn't apply properly. Our custom TOTP implementation sits **on top of** Azure AD authentication and works for any user, regardless of their email domain.